RAPPORT DE PROJET TPRM :SÉCURISATION D'UNE RELATION AVEC UN PRESTATAIRE EXTERNE SAE4.01: TP SUR LA SÉCURITÉ DES RÉSEAUX

BUT 2 R&T
(GROUPE 2)

UNIVERSITÉ SORBONNE PARIS NORD

Réalisé par :
- Tindom Sila Arol
- Seck Mahmoune
- Diallo Mawloud

Encadré par:
- Mr Hedda
- Mr Benaïssa Ouelaali

2025 - 2026

TABLES DES MATIÈRES

Introduction..... 3
1. Rôle de chaque outil dans le contexte TPRM (liens avec les TP)..... 4
pfSense : la segmentation pour isoler le tiers..... 4
Snort : la détection des comportements anormaux.....4
KeePass : le partage sécurisé des identifiants.....4
2. Analyse des risques : une attention particulière au facteur humain..... 5
Risques liés à pfSense (segmentation / filtrage).....5
Risques liés à Snort (détection d'intrusion).....5
Risques liés à KeePass (gestion des mots de passe)..... 6
Risques transversaux (organisationnels / humains).....6
3. Tableau des risques (détaillé, avec facteur humain)..... 7
4. Tableau de priorisation 3×3 (avec libellés explicites).....8
5. Mesures de réduction des risques (techniques et humaines).....9
Mesures humaines transversales.....9
6. Synthèse TPRM (1 page)..... 10
Conclusion.....11

Rapport de Projet TPRM : Sécurisation d’une relation avec un prestataire externe

Appui sur les travaux pratiques : Snort (IDS), pfSense (pare-feu), KeePass (gestion de mots de passe), TP4 (VLAN, ACL, STP), TP VSI (exploitation de mots de passe faibles, clés SSH), analyse PCAP

Introduction

Dans le cadre de notre formation, nous avons réalisé plusieurs travaux pratiques sur la sécurité des réseaux LAN : installation et configuration de Snort (système de détection d’intrusion), mise en place d’une segmentation réseau avec pfSense (ou équivalent Cisco), et utilisation de KeePass pour la gestion sécurisée des mots de passe. Ces outils sont aujourd’hui déployés par un prestataire externe qui intervient sur notre système d’information.

L’objectif de ce rapport est d’appliquer une démarche TPRM (Third-Party Risk Management) : identifier les risques liés à l’utilisation de ces trois outils par le tiers, proposer des mesures de réduction (techniques et humaines), prioriser les risques, et conclure sur l’acceptabilité de la relation.

1. Rôle de chaque outil dans le contexte TPRM (liens avec les TP)

pfSense : la segmentation pour isoler le tiers

Lors de nos exercices sur les VLAN et les ACL (TP4, exercice 2), nous avons appris à créer des réseaux virtuels séparés (Comptabilité, R&D, Visiteurs) et à contrôler les flux inter-VLAN. Pour le TPRM, nous utilisons pfSense afin de placer le prestataire dans un VLAN dédié, avec des règles très restrictives : seuls les ports et protocoles strictement nécessaires à sa mission sont autorisés. Tout autre trafic est bloqué par défaut. C'est la traduction technique du principe du *moindre privilège*.

Snort : la détection des comportements anormaux

Dans le TP Snort, nous avons installé l'IDS sur Kali Linux, configuré le fichier `snort.conf` (adresse du réseau interne, interface réseau), créé des règles personnalisées comme `alert tcp any any -> any any (msg:"Détection mot ATTAQUE"; content:"attaque"; sid:1000001;)`, puis généré du trafic de test avec Scapy. Snort a bien déclenché des alertes en temps réel. Pour le TPRM, nous positionnons Snort sur le segment réseau du tiers, en mode promiscuous, afin de surveiller toute tentative de scan, d'intrusion ou d'exfiltration.

KeePass : le partage sécurisé des identifiants

Nous avons utilisé KeePass pour stocker des mots de passe dans une base chiffrée (AES-256). Le TP sur les clés SSH (challenge Root-Me) nous a montré qu'un mot de passe trivial (`password`) ou une clé privée mal protégée peut compromettre tout un système. KeePass nous permet de transmettre au tiers les identifiants nécessaires (VPN, accès serveurs) sans jamais les envoyer en clair par email ou messagerie, et en imposant une politique de complexité.

2. Analyse des risques : une attention particulière au facteur humain

Chaque outil présente des vulnérabilités techniques, mais la majorité des incidents proviennent d'erreurs ou de négligences humaines. Nous avons identifié les risques suivants.

Risques liés à pfSense (segmentation / filtrage)

- ➔ **R1 – Mouvement latéral non bloqué** : un administrateur du tiers peut, par manque de formation ou inattention, créer une règle ACL trop large (par exemple `permit ip any any` au lieu d'un refus par défaut). Nous avons vu cette situation dans l'exercice 1 du TP4 où l'absence de VLAN rendait tout le réseau plat.
- ➔ **R2 – Interface d'administration exposée** : si le tiers laisse l'interface web de pfSense accessible avec un mot de passe par défaut ou faible (ex: `admin/admin`), un attaquant peut prendre le contrôle total du pare-feu. Le cours a souligné que les identifiants par défaut sont une cause majeure de compromission.
- ➔ **R3 – Perte de configuration** : un technicien pressé modifie la configuration sans sauvegarde préalable. En cas d'erreur, il ne peut pas revenir en arrière, ce qui allonge la durée d'indisponibilité.

Risques liés à Snort (détection d'intrusion)

- ➔ **R4 – Alertes ignorées (non-surveillance)** : l'équipe du tiers peut être surchargée ou mal formée et ne pas consulter les alertes Snort. Dans le TP, nous avons vu que les alertes s'affichent dans la console ou dans `/var/log/snort` ; sans une personne dédiée, elles passent inaperçues.
- ➔ **R5 – Faux positifs massifs** : un mauvais positionnement de Snort (par exemple en amont du firewall – position 1 du cours) génère des milliers d'alertes inutiles. L'opérateur, noyé, finit par désactiver l'IDS.
- ➔ **R6 – Règles jamais mises à jour** : par négligence ou absence de procédure, le tiers ne met pas à jour les règles Snort. Une nouvelle attaque (CVE récente) n'est alors pas détectée. Nous avions écrit nos règles manuellement ; en production, il faut automatiser les mises à jour.

Risques liés à KeePass (gestion des mots de passe)

- ➔ **R7 – Mot de passe maître faible ou partagé** : un employé du tiers peut noter le mot de passe maître sur un post-it, l'envoyer par chat, ou choisir `password` (comme dans le challenge SSH du TP VSI).
- ➔ **R8 – Coffre exposé sur un support non sécurisé** : le fichier `.kdbx` peut être copié sur une clé USB non chiffrée ou déposé sur un serveur accessible à tous. Un acteur malveillant peut alors le voler et le casser hors ligne.
- ➔ **R9 – Absence de rotation des mots de passe** : le prestataire finit sa mission, mais les mots de passe stockés ne sont jamais changés. Un ancien sous-traitant ou une personne ayant eu accès au coffre peut encore se connecter.
- ➔ **R10 – Vérification d'intégrité désactivée** : pour simplifier, l'opérateur désactive le contrôle d'intégrité ; une altération du fichier (injection de backdoor) n'est alors pas détectée.

Risques transversaux (organisationnels / humains)

- ➔ **R11 – Manque de formation générale** : les techniciens du tiers n'ont jamais manipulé Snort, pfSense ou KeePass. Ils commettent des erreurs élémentaires.
- ➔ **R12 – Turnover non géré** : un technicien formé quitte le prestataire ; son remplaçant ne connaît pas les procédures spécifiques à notre contrat.

3. Tableau des risques (détaillé, avec facteur humain)

Outil	ID	Risque (composante humaine)	Cause (TP / cours)	Impact	Probabilité	Niveau
pfSense	R1	Mouvement latéral non bloqué	Admin crée une règle trop large (TP4 ex.1)	Élevé	Moyenne	**Élevé**
pfSense	R2	Interface d'admin exposée	Mot de passe par défaut / faible (cours)	Critique	Moyenne	**Critique**
pfSense	R3	Perte de configuration	Pas de sauvegarde, manipulation humaine	Élevé	Faible	Moyen
Snort	R4	Alertes ignorées	Opérateur non formé ou surchargé	Élevé	Élevée	**Élevé**
Snort	R5	Faux positifs massifs	Mauvais positionnement (position 1)	Moyen	Élevée	Moyen
Snort	R6	Règles jamais mises à jour	Négligence, absence de procédure	Élevé	Moyenne	**Élevé**
KeePass	R7	Mot de passe maître faible ou partagé	Post-it, chat, mot trivial (TP VSI)	Critique	Élevée	**Critique**
KeePass	R8	Coffre exposé	Stockage non sécurisé du `.kdbx`	Critique	Moyenne	**Critique**
KeePass	R9	Absence de rotation	Identifiants toujours valides après mission	Élevé	Élevée	**Élevé**
KeePass	R10	Intégrité désactivée	Opérateur désactive le contrôle	Moyen	Faible	Moyen
Transversal	R11	Manque de formation	Techniciens jamais formés aux outils	Élevé	Moyenne	**Élevé**
Transversal	R12	Turnover non géré	Départ d'un technicien formé	Élevé	Moyenne	**Élevé**

Niveaux : Critique → à traiter en priorité absolue ; Élevé → risque significatif ; Moyen → acceptable sous surveillance.

4. Tableau de priorisation 3×3 (avec libellés explicites)

Ce tableau croise **l'impact** (Critique, Élevé, Moyen) et la **probabilité** (Faible, Moyenne, Élevée) pour chaque risque identifié.

Impact \ Probabilité	Faible	Moyenne	Élevée
Critique		**R2** – Interface pfSense exposée **R7** – Mot de passe maître faible/partagé **R8** – Coffre KeePass exposé	
Élevé	**R3** – Perte de configuration pfSense	**R1** – Mouvement latéral (pfSense) **R6** – Règles Snort obsolètes **R9** – Absence rotation mots de passe **R11** – Manque de formation **R12** – Turnover non géré	**R4** – Alertes Snort ignorées
Moyen	**R10** – Intégrité KeePass désactivée	**R5** – Faux positifs Snort massifs	

Lecture :

- ➔ Les risques dans la case Critique + Moyenne (R2, R7, R8) sont les plus dangereux → action immédiate.
- ➔ Le risque R4 (Alertes Snort ignorées) est très probable et d'impact élevé → priorité également très haute.
- ➔ Les risques en case Moyen (R5, R10) sont acceptables mais doivent être surveillés.
- ➔ Les cases vides indiquent qu'aucun risque de ce couple (impact/probabilité) n'a été identifié.

5. Mesures de réduction des risques (techniques et humaines)

Pour pfSense

- ➔ **Technique** : Appliquer *deny by default*, n'autoriser que les flux explicitement nécessaires. Interface d'administration accessible uniquement via VPN avec MFA (Google Authenticator). Sauvegarde automatique quotidienne de `/cf/conf/config.xml` vers un serveur distant.
- ➔ **Humaine** : Exiger que les administrateurs du tiers soient certifiés ou aient suivi une formation pfSense. Mettre en place une validation croisée : toute modification de règle doit être relue par un second technicien. Désigner un responsable sécurité

Pour Snort

- ➔ **Technique** : Positionner Snort en DMZ (position 2 du cours) pour réduire les faux positifs. Mise à jour automatique des règles via `pulledpork` chaque semaine. Centralisation des logs vers notre SIEM (Zabbix).
- ➔ **Humaine** : Le tiers doit désigner une personne en astreinte pour la surveillance des alertes. Formation obligatoire à l'interprétation des règles Snort (savoir lire `sid`, `msg`, `content`). Contrat : toute alerte de sévérité ≥ 2 doit être remontée dans l'heure. Simulation mensuelle d'attaque (envoi d'un paquet avec le mot « attaque » comme dans le TP) pour tester la réaction.

Pour KeePass

- ➔ **Technique** : Mot de passe maître d'au moins 16 caractères, avec un keyfile stocké physiquement à part (clé USB). Chiffrement AES-256 et vérification d'intégrité activée. Stockage du fichier `.kdbx` dans un conteneur VeraCrypt ou sur un serveur à droits très stricts.
- ➔ **Humaine** : Interdiction formelle de partager le mot de passe maître par email, chat ou post-it. Rotation obligatoire des mots de passe stockés tous les 90 jours (calendrier partagé). À la fin de la mission, le tiers doit fournir la preuve de rotation (logs KeePass). Sensibilisation au phishing.

Mesures humaines transversales

- ➔ Clauses contractuelles : le tiers s'engage à former ses employés (attestation fournie). Un référent sécurité est désigné. Droit d'audit humain inopiné (nous pouvons interroger un technicien sur ses pratiques).
- ➔ Plan de réponse : en cas d'incident lié à une erreur humaine (ex : mot de passe divulgué), révocation dans les 4 heures.

6. Synthèse TPRM (1 page)

Acceptabilité de l'usage de Snort, pfSense et KeePass par un prestataire externe

Décision : **Acceptable** : mais sous conditions techniques et humaines strictes.

Pourquoi acceptable ? Nous ne comptons pas uniquement sur la bonne volonté du tiers. Nous mettons en place une défense en profondeur qui compense les faiblesses humaines potentielles :

- ➔ pfSense segmente physiquement le tiers → même si un administrateur fait une erreur de règle, l'impact est limité.
- ➔ Snort surveille en temps réel et centralise ses alertes chez nous → si le prestataire oublie de consulter ses logs, nous recevons une copie.
- ➔ KeePass impose un double facteur → un vol de mot de passe seul ne suffit pas.

Le facteur humain est la clé : 80 % des incidents sont liés à une erreur humaine. Nous avons donc intégré dans le contrat des obligations comportementales :

- ➔ Formation obligatoire des opérateurs (attestation).
- ➔ Désignation d'un responsable sécurité chez le tiers.
- ➔ Simulation mensuelle d'attaques pour vérifier la réaction.
- ➔ Audit humain inopiné : nous pouvons demander à un technicien de montrer comment il consulte les logs ou change un mot de passe.
- ➔ Clause de non-partage des secrets avec pénalités financières.

Conditions d'acceptation (extrait contractuel)

Domaine	Condition humaine / organisationnelle
pfSense	Les modifications de règles sont double-validées. L'administrateur suit une formation annuelle
Snort	Un opérateur est dédié à la supervision des alertes (astreinte). Le tiers accepte des tests d'intrusion mensuels simulés
KeePass	Le mot de passe maître n'est jamais partagé ; rotation obligatoire à la fin de chaque mission
Général	Le tiers autorise des audits humains inopinés et fournit un plan de réponse aux départs

Risque résiduel : Après application de ces mesures, le risque résiduel est maîtrisé. Le seul risque non totalement éliminé est l'erreur humaine imprévisible. Nous l'acceptons car :

- ➔ Les outils techniques (MFA, segmentation, logs) limitent les dégâts.
- ➔ La valeur métier apportée par le tiers dépasse le risque résiduel.

Décision finale : **Approuvé** : mise en œuvre des conditions humaines et techniques avant le début de la prestation, avec un audit humain dans les trois premiers mois.

Conclusion

Ce travail nous a permis de concrétiser la démarche TPRM en l'appliquant à trois outils que nous avons manipulés en TP. Nous avons vu que la technique seule (règles Snort, ACL pfSense, chiffrement KeePass) ne suffit pas : l'erreur humaine, le manque de formation, le turnover ou la simple négligence sont des risques majeurs. En intégrant des mesures comportementales (double validation, astreinte, simulations d'attaque, audits humains) dans le contrat, nous transformons une relation tiers potentiellement dangereuse en un accès contrôlé, auditable et sécurisé.

Les références aux TP (création de règles Snort avec le mot « attaque », test avec Scapy, configuration des VLAN et ACL, exploitation du mot de passe `password` dans le challenge SSH) nous ont servi de preuves concrètes pour justifier nos analyses.